

عملیات، زیرساخت و تداوم کسب و کار PEYVO - راهنمای

Operational, Infrastructure & Business Continuity Handbook

نسخه سند	1.0
تاریخ	2026-08-18
Commit	c6893bcd90d815049cc5b8b82f66af0b09832c0
Production	https://peyvo.ir

محرمانه عملیاتی - بدون رمز و کلید. این سند را فقط در اختیار مالک و اپراتور مورد اعتماد قرار دهید.

فهرست مطالب

راهنمای وضعیت شواهد	4
1. خلاصه مدیریتی	5
2. معماری کامل سامانه	6
2.1 نمودار A - معماری کلان	6
2.2 اجزای اصلی	6
3. موجودی زیرساخت	8
4. نقشه دسترسی و مالکیت	9
5. فرایند استقرار Production	10
5.1 مسیر استاندارد	10
5.2 کنترل migration	10
5.3 Rollback	10
6. مستندات دیتابیس	11
6.1 گروه مدل‌ها	11
6.2 جداول بحرانی	11
6.3 جداسازی Tenant	11
6.4 داده حساس در حالت سکون	11
7. بکاپ و بازیابی بحران	13
7.1 وضعیت فعلی	13
7.2 حداقل راهبرد پیشنهادی	13
7.3 دستورهای امن نمونه	13
8. فهرست امن Environment Variable ها	14
9. معماری امنیت	15
9.1 کنترل‌های موجود	15
9.2 ریسک‌های شناسایی شده	15
10. پرداخت و اشتراک	17
10.1 نمودار B - پرداخت تا entitlement	17
10.2 وب، کیف پول و فاکتور	17
10.3 سناریوهای شکست	17
11. Myket و Cafe Bazaar	19
11.1 Myket	19
11.2 Cafe Bazaar	19
12. معماری Android / Capacitor	20
12.1 ساخت‌ها	20
13. معماری AI	21

13.1 نمودار C	21
14. قابلیت AI: دستیار پذیرش تعمیر	22
15. پایش و عیب یابی	23
15.1 سایت Down	23
15.2 Vercel deployment failed	23
15.3 Database connection failed	23
15.4 Prisma migration failed	23
15.5 پرداخت موفق ولی اشتراک فعال نیست	23
15.6 SMS ارسال نشد	23
15.7 AI connection failed	24
15.8 Android app fails	24
15.9 خرید Myket/Bazaar	24
16. پاسخ به حادثه	25
17. چرخش Credentials	26
18. برنامه تداوم کسب و کار	27
اگر توسعه دهنده اصلی در دسترس نباشد	27
19. چک لیست یک صفحه ای اضطراری	28
سرویس های حیاتی	28
مسیرهای فوری	28
تماس ها	28
20. نمودارهای وابستگی	29
21. ماتریس وضعیت فعلی	30
22. تأیید شده، تأیید نشده و اقدام انسانی	31
VERIFIED	31
NOT VERIFIED	31
REQUIRES HUMAN ACTION	31
23. فراداده و کنترل تغییر سند	32
24. الزامات نگهداری PDF	33
25. اعتبارسنجی نهایی	34
پنج ریسک مهم	34
پنج اقدام فوری	34

شناسه استقرار Vercel: NOT VERIFIED (هدر مشاهده شد، ولی شناسه Deployment از داشبورد در دسترس نبود)
https://peyvo.ir: مخزن: behnam391/repair-saas-final دامنه عملیاتی: c6893bcd90d815049cc5b8b82f66af0b09832c0
سند: 1.0 تاریخ تولید: ۱۴۰۵/۰۵/۲۷ (18-08-2026) آخرین بازبینی: Asia/Tehran Commit 00:30 18-08-2026 بررسی شده:
پروژه: Peyvo (پیوو) نوع سند: Operational, Infrastructure & Business Continuity Handbook نسخه

API Key، Token، Private Key، Merchant ID، یا کلید امضای اندروید ندارد. نسخه چاپی باید در محل امن نگهداری شود.
طبقه بندی امنیتی: محرمانه عملیاتی - بدون رمز و کلید. این سند عمداً هیچ گذرواژه، Connection String

راهنمای وضعیت شواهد

- (VERIFIED): مستقیماً از کد، migration، schema، پاسخ عمومی سرویس، DNS یا خواندن امن تنظیمات بررسی شده است.
 - تأیید شده
- استنباط شده (INFERRED): نتیجه منطقی از شواهد است، اما داشبورد مالک سرویس مشاهده نشده است.
- تأیید نشده (NOT VERIFIED): برای تأیید به حساب مالک، داشبورد بیرونی یا سند قراردادی نیاز دارد.
- اقدام انسانی (HUMAN ACTION): فقط مالک حساب یا اپراتور مورد اعتماد می تواند انجام دهد.

1. خلاصه مدیریتی

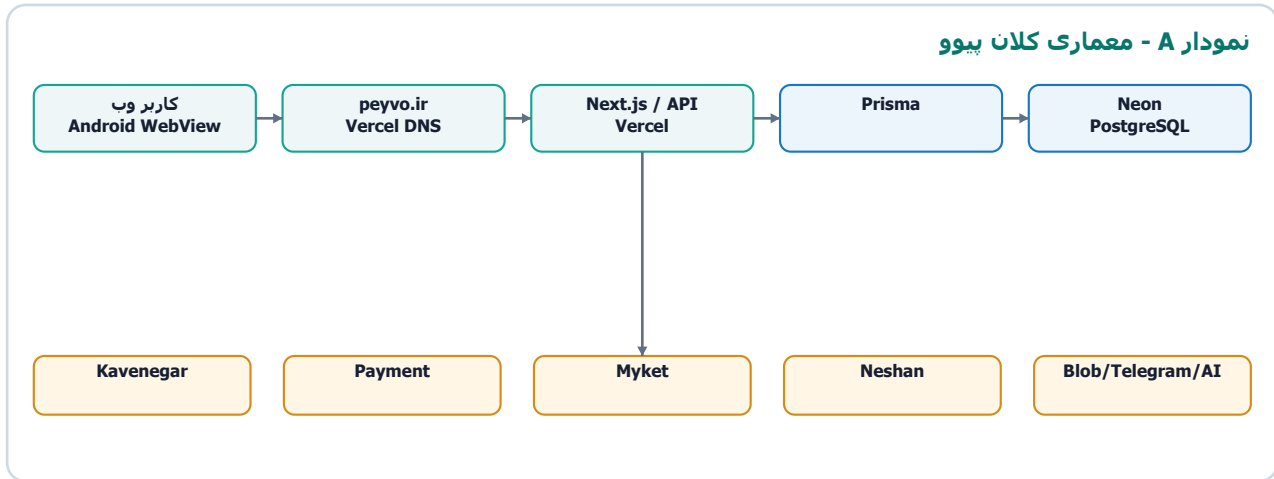
فاکتور و پرداخت، همکاری بین مغازه‌ها، پیامک، کیف پول/اشتراک، پنل مشتری و اپ اندروید را در یک سامانه وب متمرکز می‌کند. برای مدیریت تعمیرگاه و فروشگاه موبایل است. محصول، پذیرش دستگاه، مشتریان، گردش تعمیر، تکنسین‌ها، موجودی، پیوو یک سامانه SaaS چندمستأجری

موضوع	وضعیت	شواهد
کاربران هدف	موبایل، فروشندگان/همکاران، کارکنان و مشتریان تعمیرگاه‌های	VERIFIED از مدل‌ها و صفحات
مدل کسب و کار	حرفه‌ای و تجاری؛ خرید مدت‌دار و کد هدیه پلن رایگان،	VERIFIED از lib/plans.ts و billing
وب عمومی	https://peyvo.ir با HTTPS و پاسخ 200	VERIFIED در 18-08-2026
میزبانی	Next.js روی Vercel	VERIFIED از هدر Server: Vercel و مخزن
دیتابیس	با Prisma؛ اتصال محلی به Neon مشاهده شد PostgreSQL	Region: NOT VERIFIED / نام پروژه و VERIFIED
اندروید	شناسه com.peyvo.app، نسخه 1.2 / 3 code، Capacitor 8	VERIFIED
توزیع اندروید	وضعیت انتشار نهایی بازار/مایکت تأیید نشده APK مستقیم در GitHub Release؛	VERIFIED / NOT VERIFIED
پرداخت وب	فعال؛ abstraction برای Zibal و NextPay Zarinpal	VERIFIED از تنظیمات امن و کد
پرداخت مایکت	پذیرش فروشگاه و خرید واقعی تأیید نشده سروری پیاده‌سازی شده؛ کلیدها تنظیم‌اند؛ verify و SDK	VERIFIED / NOT VERIFIED
پرداخت بازار	وجود دارد؛ provider/SDK واقعی بازار پیاده نشده فقط فیلدهای تنظیمات	VERIFIED - unfinished
پیامک	Kavenegar و Lookup فعال/تنظیم‌شده	تنظیمات امن؛ تحویل واقعی دوره‌ای نیازمند پایش از VERIFIED
AI	دارد؛ وضعیت تولیدی فعلی خاموش/disabled معماری provider-agnostic وجود	VERIFIED
بکاپ	JSON به Telegram در کد و تنظیمات وجود دارد Cron روزانه	موفقیت روزانه/retention: NOT VERIFIED؛ VERIFIED

محدودیت اصلی: تداوم سرویس به چند حساب شخصی، اجرای صحیح بکاپ و نگهداری کلید امضای اندروید وابسته است. است؛ بازار فاقد خرید درون‌برنامه‌ای است؛ مایکت بدون تأیید خرید واقعی؛ بازیابی خودکار و مانیتورینگ بیرونی اثبات نشده‌اند. گردش تعمیر، فاکتور، پرداخت وب، پیامک، اندروید WebView، ثبت خطا، مهاجرت‌های Prisma، آزمایشی/ناتمام: AI واقعی خاموش آماده تولید: وب، احراز هویت نقش‌محور،

2. معماری کامل سامانه

2.1 نمودار A - معماری کلان



2.2 اجزای اصلی

جزء	هدف / Provider	وابستگی	اثر خرابی	بازیابی / جایگزین
دامنه peyvo.ir	ورودی عمومی	DNS روی Vercel	کامل دسترسی و callback قطع	مالک دامنه، اصلاح NS/A بازیابی
Vercel	میزبانی Next.js و Cron	env و GitHub	سایت/API از دسترس خارج	rollback deployment یا provider جایگزین
Next.js 14.2.5	API و UI	Node، env، DB	اختلال محصول	build از commit سالم
Prisma 5.20	ORM و migration	DATABASE_URL	APIهای داده‌ای متوقف	generate/migrate deploy
Neon PostgreSQL	داده عملیاتی	اتصال شبکه و credential	تقریباً کل محصول متوقف	restore dump یا PITR/provider backup
Capacitor 8.4.2	پوسته Android	دامنه پیوو	اپ بدون وب عملاً بلااستفاده	rebuild یا تغییر server URL و انتشار APK جدید
Kavenegar	و پیام‌های پذیرش/آمادگی OTP	API key/template	ورود/بازیابی یا اعلان مختل	Lookup/free-form، provider جایگزین
Payment gateways	پرداخت وب	Merchant/API credentials	فاکتور مختل خرید/شارژ/پرداخت	reconciliation، تنظیمات، تغییر provider
Myket	پرداخت درون برنامه‌ای	SDK + RSA + access token	اشتراک در APK مایکت مختل خرید	config/SDK، رفع فروشگاه‌ها، وب فقط خارج از build
Neshan	نقشه	web API key	انتخاب موقعیت/نقشه مختل	مختصات یا provider جایگزین ورود دستی
Vercel Blob	تصاویر عمومی	Blob token	در تولید شکست می‌خورد آپلود تصویر	جدید یا object storage دیگر Blob
Telegram	مقصد بکاپ JSON	bot token/chat	تحويل نمی‌شود بکاپ زمان‌بندی شده	امن + storage رمزگذاری شده داندلود دستی
AI endpoint	پیشنهاد پذیرش	API key/base URL	مختل، نه جریان اصلی فقط AI helper	خاموش‌سازی/fallback/mock

data در داشبوردها NOT VERIFIED است. هدر درخواست، Vercel را تأیید می‌کند ولی برای تصمیم حقوقی/داده‌ای کافی نیست.
Region: محل دقیق Vercel project، Neon، residency

3. موجودی زیرساخت

سرویس	هدف	مالک / شناسه	مدیریت / تولید URL	تنظیم مهم	محل Credential	بازرسی	اهمیت
GitHub	سورس و تاریخچه	(Owner: behnam391 (VERIFIED	github.com / repo above	branch main	Git credential manager / 2FA	+ مالک پشتیبان recovery codes	Critical
Vercel	deploy, domain, cron	Project/Team NOT VERIFIED	vercel.com / peyvo.ir	env, Git integration, Cron	Vercel encrypted env	account recovery + import repo	Critical
دامنه IR	مالکیت peyvo.ir	Registrar/holder NOT VERIFIED	nic.ir / registrar unknown	NS: Vercel DNS	registrar account	recovery email/phone	Critical
DNS	resolution	Vercel DNS	Vercel Domains	ns1/ns2.vercel-dns.com	Vercel account	recreate records	Critical
Neon PostgreSQL	DB	Project/region NOT VERIFIED	console.neon.tech	connection string	Vercel env + secure local env	Neon PITR/export	Critical
Vercel Blob	تصاویر	status NOT VERIFIED	Vercel Storage	BLOB_READ_WRITE_TOKEN	Vercel env	reconnect/create store	High
Kavenegar	SMS/OTP	account owner NOT VERIFIED	panel.kavenegar.com	sender, Lookup templates	encrypted PlatformSettings / env fallback	rotate key/templates	High
Zarinpal	gateway فعال	merchant owner NOT VERIFIED	zarinpal.com	registered callback domain	encrypted PlatformSettings / env	rotate merchant credential	Critical
Zibal/NextPay	gateway جایگزین	not configured	provider panels	provider switch	encrypted settings/env	configure when required	Medium
Neshan	map	owner NOT VERIFIED	platform.neshan.org	domain-restricted web key	PlatformSettings	rotate/restrict	Medium
Myket	Android billing	developer account NOT VERIFIED	developer.myket.ir	package, products, access token	encrypted settings/env	account recovery + rotate token	High
Cafe Bazaar	store future billing	developer account NOT VERIFIED	developers.cafebazaar.ir	package/products	encrypted settings	implement provider then release	High
Telegram	backup destination	bot/chat owner NOT VERIFIED	Telegram	bot + private chat/channel	encrypted settings	new bot/chat + test	Critical
SMTP	email recovery	provider NOT VERIFIED	host hidden	host/user/from	password encrypted; metadata DB	rotate/retest	Medium
AI provider	optional AI	provider NOT VERIFIED	configured base URL hidden	primary/fallback/ model	encrypted settings/env	disable/rotate/switch	Low now
GitHub Release	APK مستقیم	repo owner	release v1.2.0	immutable artifact discipline	GitHub account	re-upload signed artifact	High
ErrorLog	self-hosted monitoring	Peyvo DB	Super Admin errors	no external alerting	DB	inspect/resolve/export	Medium

تأییدشده در vercel.json: یادآوری اشتراک هر روز 06:00 UTC و بکاپ هر روز 03:00 UTC. هر دو به CRON_SECRET وابسته‌اند.
Cron‌های

4. نقشه دسترسی و مالکیت

دارایی	مالک اصلی	مالک بازیابی	2FA	ریسک تک نفره
GitHub	حساب behnam391	NOT VERIFIED	باید فعال باشد	High تا تعیین پشتیبان
Vercel	NOT VERIFIED	NOT VERIFIED	الزامی پیشنهادی	Critical
دامنه/NIC	NOT VERIFIED	NOT VERIFIED	recovery phone/email	Critical
Neon	NOT VERIFIED	NOT VERIFIED	الزامی پیشنهادی	Critical
Zarinpal/Kavenegar	NOT VERIFIED	NOT VERIFIED	الزامی پیشنهادی	High
Myket/Bazaar	از مکاتبه قبلی - INFERRED بهنام شفیعی	NOT VERIFIED	الزامی	High
Telegram backup	NOT VERIFIED	حداقل دو admin	الزامی	Critical
Android signing key	محلی NOT VERIFIED نگهدارنده	نسخه رمزگذاری شده آفلاین	N/A	Critical

پشتیبان در repository وجود ندارد؛ بنابراین همه موارد فوق تا تأیید مالک، single-person dependency محسوب می‌شوند. دو فرد مورد اعتماد، recovery email مستقل، شماره بازیابی به‌روز و recovery code آفلاین لازم است. هیچ مدرکی از دسترسی قاعده عملیاتی: برای تمام موارد Critical،

5. فرایند استقرار Production

5.1 مسیر استاندارد

git commit -> git push origin main -> migration میسررب -> npm run check -> دک ری ریخت
 -> Vercel build -> prisma generate -> prisma migrate deploy -> next build
 -> deployment -> smoke test پور Peyvo.ir

دستور	زمان اجرا	کار	شکست محتمل	نایید موفقیت
npm ci	clone/CI	نصب دقیق lockfile	نسخه Node/registry	exit 0
npm run dev	توسعه محلی	Next dev	env/DB/port	بازشدن localhost
npm run check	قبل commit	TypeScript + 40 test	type/test regression	همه tests pass
npm run typecheck	قبل commit	tsc --noEmit	type mismatch	exit 0
npm test	قبل commit	AI/security/subscription تست‌های	env ناخواسته یا regression	pass 40/40 در این بررسی
npm run build	Vercel/آزمون کنترل‌شده	generate + migrate deploy + Next build	خطا DB unavailable/migration	build success + migrations applied
npm run db:deploy	migration production	migrate deploy	drift/lock/connection	schema check و Prisma success
npm run prisma:migrate -- --name NAME	فقط DB dev	ساخت migration	اتصال اشتباه به prod	فایل review SQL شود
npm run android:sync	قبل build Android	sync Capacitor	dependency/webDir	Gradle project updated
cd android; .\gradlew.bat assembleRelease	APK release	build release	JDK/signing/SDK	signature verification و APK

script Lint: مستقل lint در package.json وجود ندارد - NOT IMPLEMENTED.

5.2 کنترل migration

prisma را اجرا می‌کند؛ این از db push امن‌تر است، اما deployment به دسترسی write دیتابیس وابسته است. قبل از push: Build فعلی migrate deploy

1. SQL migration را بخوانید؛ DROP, TRUNCATE, تغییر nullable/type و index بزرگ را علامت‌گذاری کنید.
2. روی clone/staging restore شده تست کنید.
3. بکاپ قابل بازیابی و timestamp آن را ثبت کنید.
4. سپس deploy کنید.

5.3 Rollback

- کد: در deployment، Vercel، سالم قبلی را Promote/Rollback کنید یا commit اصلاحی بسازید.
- دیتابیس: rollback کد لزوماً migration را برنمی‌گرداند. migration برگشتی جداگانه یا PITR لازم است.
- هرگز git reset --hard یا prisma db push روی production به‌عنوان روش اضطراری استفاده نشود.

6. مستندات دیتابیس

جدول‌های کسب و کاری shopId دارند. جداسازی در لایه برنامه با requireSession() و شرط shopId { where: { انجام می‌شود. Prisma datasource، PostgreSQL، Provider: DATABASE_URL، معماری: یک دیتابیس مشترک چندمستأجری؛ اکثر

6.1 گروه مدل‌ها

حوزه	مدل‌های کلیدی
هویت/مالکیت	Shop, User, PlatformAdmin, PlatformCustomer, Customer
تعمیر	Ticket, TicketHistory, TicketMessage, PendingIntake, ReturnRecord
مالی	Invoice, InvoiceItem, Subscription, PurchaseRecord, WalletTransaction, Expense, GiftCode
موجودی/فروش	InventoryItem, TicketPart, DealerInventory, MarketListing
همکاری	ShopPartnership, ShopReferral, Conversation, Message
امنیت/ممیزی	ImpersonationToken, PasscodeAccessLog, AiConfigAudit, ErrorLog, RateLimitBucket
AI	AiSuggestion, PlatformSettings AI fields
خارجی	ExternalApiKey, DeviceFlag, DeviceTransaction, Rating

6.2 جداول بحرانی

- Shop: entitlement, plan, quota، فعال‌بودن و مانده کیف پول.
- User, PlatformAdmin, PlatformCustomer: password hash و هویت.
- Ticket, Customer, Invoice: عملیات روزانه و تعهد مالی.
- Subscription, PurchaseRecord, WalletTransaction: اثبات پرداخت و entitlement.
- PlatformSettings: تنظیمات و ciphertext سرویس‌های حیاتی.
- Ticket.devicePasscode: رمز دستگاه رمزگذاری‌شده؛ به master key وابسته.

6.3 جداسازی Tenant

کند. اقدام: تست خودکار tenant-boundary برای همه route‌ها و سپس RLS دفاعی PostgreSQL یا repository layer اجباری. یافت نشد. بنابراین حفاظت کاملاً application-level است و یک route بدون shopId می‌تواند نشت بین مستأجرها ایجاد را رد می‌کند؛ گارد های Desk/Capability برای عملیات مالی وجود دارد. ریسک: هیچ RLS/Policy در hamigration VERIFIED: JWT کاربر مغازه shopId و role دارد؛ requireSession جلسات مشتری/سوپردمین

6.4 داده حساس در حالت سکون

- password با hash cost 10 bcrypt می‌شوند.
- با AES-256-GCM و SECRETS_MASTER_KEY رمز می‌شوند؛ ولی helper در نبود master key plaintext passthrough دارد.
- PlatformSettings secret و device passcode

- plaintext قابل lookup و از API سوپرادمین قابل برگشت است - ریسک High؛ بهتر است hash + prefix/last4 ذخیره شود.
- ExternalApiKey.apiKey به صورت
- PurchaseRecord.raw تا 4000 کاراکتر payload provider می‌کند؛ باید داده شخصی/رسید حداقلی بماند.

7. بکاپ و بازیابی بحران

7.1 وضعیت فعلی

دارد. NOT VERIFIED: آخرین اجرای موفق، retention، رمزگذاری فایل در مقصد، سلامت PITR، bot/chat و retention پلن Neon. JSON مورد انتظار و ارسال به Telegram تنظیم شده است؛ دانلود دستی و restore non-destructive در پلن سوپرادمین وجود VERIFIED: Cron روزانه snapshot/، backup/، api/cron/ کامل

و RateLimitBucket در snapshot/restore فعلی پوشش کامل ندارند. بنابراین عبارت «full backup» در comment کد دقیق نیست. با schema فعلی همگام نیستند. حداقل PurchaseRecord, AiSuggestion, AiConfigAudit, PasscodeAccessLog هشدار بحرانی: BACKUP_MODELS و RESTORE_ORDER

ارسال decrypt نمی‌کند، درحالی‌که cron این کار را می‌کند. تست دستی ممکن است با credential رمز شده شکست بخورد. نکته دوم: مسیر POST تست دستی بکاپ، token ذخیره شده را قبل

7.2 حداقل راهبرد پیشنهادی

1. بکاپ Neon provider-native/PITR را فعال و retention را مستند کنید.
2. روزانه pg_dump رمزگذاری شده در object storage مستقل با 30 retention روز.
3. snapshot برنامه‌ای را با schema sync و schemaVersion ارتقا دهید.
4. فایل Telegram را نسخه دوم، نه تنها نسخه بکاپ بدانید.
5. ماهانه restore روی دیتابیس جداگانه و smoke test انجام دهید.
6. RPO هدف: 24 ساعت حداقل؛ با PITR بهتر، 5-15 دقیقه. RTO هدف: 2-4 ساعت.

7.3 دستورهای امن نمونه

```
# نام shell رد و یست درصوم سیبانی URL اب طوف
pg_dump --format=custom --no-owner --file peyvo-YYYYMMDD.dump $env:DATABASE_URL
pg_restore --list peyvo-YYYYMMDD.dump
pg_restore --clean --if-exists --no-owner --dbname $env:TEST_DATABASE_URL peyvo-YYYYMMDD.dump
```

write را متوقف، سپس از آخرین dump/PITR به PostgreSQL جایگزین restore و DATABASE_URL را در Vercel تغییر دهید. command history یا PDF قرار ندهید. اگر Neon unavailable شد، DNS/connection را بررسی، maintenance banner فعال، Connection string را در chat

8. فهرست امن Environment Variable ها

نام	هدف	Production	محل معمول	چه چیزی را می شکند نبودن	Rotation
DATABASE_URL	اتصال Prisma/Postgres	Required	Vercel env	تقریباً کل API/build	DB, update env, redeploy جدید credential
NEXTAUTH_SECRET	امضای JWT/cookie	Required	Vercel env	نامن یا خراب session/auth	همه session ها logout مقدار جدید:
NEXTAUTH_URL	canonical auth URL	Recommended	Vercel env	redirect/callback	https://peyvo.ir تنظیم روی
OTP_HASH_SECRET	OTP کد HMAC	Recommended	Vercel env	نامعتبر؛ fallback NextAuth جاری OTP جاری	expire rotate, OTP
SECRETS_MASTER_KEY	DB decrypt secret	Critical	Vercel env + escrow	passcode unreadable و SMS/payment/AI	هرگز مستقیم عوض نشود new با re-encrypt>:old- ابتدا
CRON_SECRET	حفاظت cron	Required	Vercel env	cron unauthorized/fail	sync Vercel Cron و rotate
PUBLIC_APP_URL	callback/QR/SMS domain	Required	Vercel env	Vercel URL/اشتباه URL	https://peyvo.ir
NEXT_PUBLIC_APP_URL	لینک client	Recommended	Vercel env	برخی لینک ها	redeploy پس از تغییر
BLOB_READ_WRITE_TOKEN	upload تصاویر	Required if uploads	Vercel env	upload production 503	reconnect و Blob در rotate
KAVENEGAR_API_KEY	fallback SMS	Conditional	Vercel env	SMS اگر DB خالی	rotate provider/settings
KAVENEGAR_SENDER	sender SMS	Conditional	Vercel env	ارسال آزاد	replace approved sender
ZARINPAL_MERCHANT_ID	fallback payment	Conditional	Vercel env	پرداخت اگر DB خالی	rotate/re-register callbacks
ZIBAL_MERCHANT / NEXTPAY_API_KEY	gateway جایگزین	Optional	Vercel env	provider مربوط	rotate provider
PAYMENT_PROVIDER	provider fallback	Optional	Vercel env	default Zarinpal	test بعد switch
MYKET_PACKAGE_NAME	package verify	Required Myket	Vercel env/default	verify mismatch	معمولاً ثابت
MYKET_RSA_PUBLIC_KEY	SDK public key fallback	Required Myket	settings/env	setup billing	replace from console/build
MYKET_ACCESS_TOKEN	server verify	Required Myket	settings/env	verify purchase	revoke/issue token
*_AI	provider/model/quota	Optional	settings/env	فقط AI	disable, rotate keys, test probe
*_PEYVO_KEYSTORE	Android signing local/CI	Required release	secret manager local/CI	signed release	keystore normally cannot be replaced without store process

وجود دارند و با وجود master key باید encrypted باشند؛ وضعیت SECRETS_MASTER_KEY در Vercel NOT VERIFIED است. DATABASE_URL در محیط محلی set بود؛ این درباره Vercel چیزی را اثبات نمی کند. secret های سرویس در PlatformSettings وضعیت محلی مشاهده شده: فقط

9. معماری امنیت

9.1 کنترل‌های موجود

- NextAuth Credentials با JWT؛ چهار provider جدا: shop، super-admin، customer، impersonation.
- bcrypt برای password؛ OTP پنج رقمی با HMAC و timing-safe comparison.
- guardهای requireSession، requireDeskSession، requireSuperAdmin، requireCustomer، requireCapability.
- revalidation session برای user/shop/customer غیرفعال.
- impersonation یک‌بارمصرف، 10 دقیقه‌ای و وابسته به consent مغازه.
- AES-256-GCM برای secret‌های DB و passcode دستگاه؛ ممیزی reveal passcode.
- payment token matching + server verify + transaction/idempotency.
- rate limit توزیع‌شده DB برای 13 نقطه؛ upload محدود و signature فایل بررسی می‌شود.
- security headers: HSTS، Referrer، nosniff، X-Frame-Options DENY، Vercel، Permissions Policy.
- log بدون محتوا و AI redaction.

9.2 ریسک‌های شناسایی‌شده

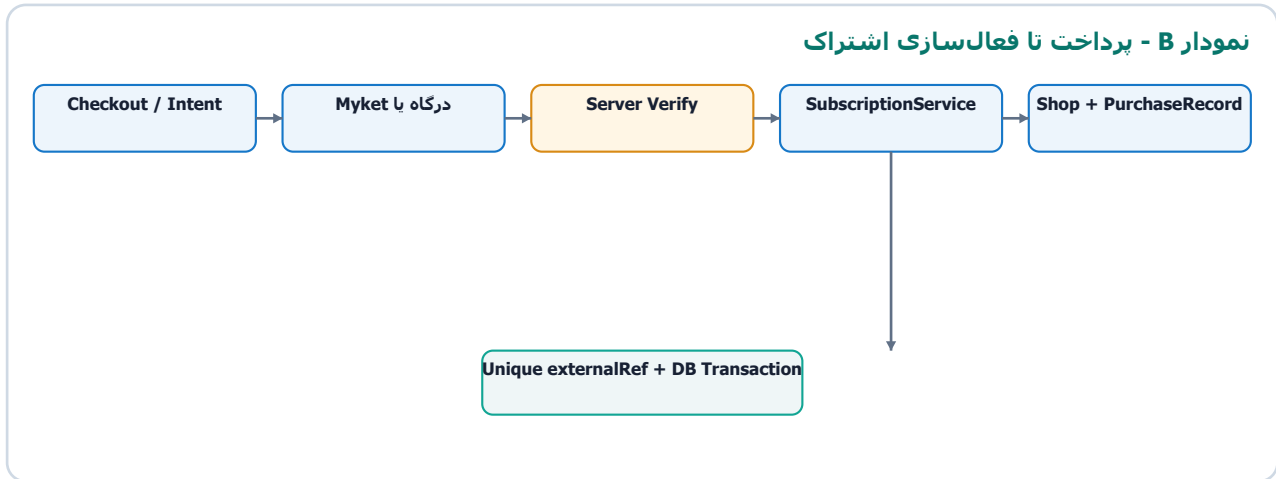
شدت	ریسک	محدوده	کنترل فعلی	اقدام/اولویت
Critical	بکاپ ناقص نسبت به schema	DR	Telegram + manual backup	sync model list + provider backup - P0
Critical	حساب‌ها/ signing key تک‌نفره بودن مالکیت	continuity	نامشخص	owner map + escrow + backup admins - P0
High	tenant فقط application-level isolation	همه داده مغازه‌ها	shopId و guard	test coverage + RLS - P1
High	نشده؛ plaintext fallback تولیدی تأیید SECRETS_MASTER_KEY	settings/passcodes	AES helper	encrypt backfill - P0 و verify key
High	و GET API آن را برمی‌گرداند External API key plaintext	external integrations	superadmin guard/scopes	hash keys، one-time display - P1
High	عمومی قابل دریافت است API key نقشه از endpoint	Neshan quota/billing	public web key	P1 endpoint حداقلی - P1 :domain restriction + rotation
High	در مکالمه انسانی افشا شده API کلید Kavenegar قبلا	SMS	encrypted DB	rotate و revoke قدیمی - P0 فورا
Medium	login guard صریح دیده نشد :route 121 در rate limit فقط 13 استفاده	abuse/auth	OTP/upload/log routes برخی	public mutations - P1 و rate-limit login
Medium	alert بیرونی اثبات نشده فقط DB/log کنسول، monitoring	عملیات	ErrorLog	uptime + Sentry/alerts - P1
Medium	android:allowBackup=true	Android	WebView/session dependent	backup rules - P2 یا disable :threat review
Medium	شامل hash و PII است backup JSON	privacy	HTTPS/superadmin	encrypt at rest + access retention - P1

شدت	ریسک	محدوده	کنترل فعلی	اقدام/اولویت
Medium	ولی billing واقعی نیست در secret list رمز می شوند کلیدهای عمومی Bazaar	release	settings only	«implemented» تفکیک - P2 از «configured» با

PostgreSQL یافته شده placeholder/documentation بودند. این اسکن جایگزین ابزار تخصصی secret scanning در CI نیست. اسکن مخزن و تاریخچه، private key یا Kavenegar key شناخته شده را پیدا نکرد. URL های

10. پرداخت و اشتراک

10.1 نمودار B - پرداخت تا entitlement



10.2 وب، کیف پول و فاکتور

- provider فعال: Zarinpal، Zibal و NextPay در abstraction موجودند.
- checkout اشتراک فقط OWNER؛ مبلغ از pricing سرور گرفته می‌شود.
- پرداخت از کیف پول در Subscription، transaction و WalletTransaction و Shop را به‌روز می‌کند.
- gateway callback بدون session است ولی token ذخیره‌شده را match و از provider verify می‌کند.
- unique externalRef و PurchaseRecord از SubscriptionService mutation انجام می‌شود.
- مشتری مانده مبلغ را پرداخت می‌کند؛ callback مقدار pending را verify و paidAmount را transactionally افزایش می‌دهد.
- فاکتور
- GiftCode یک‌بارمصرف و اتمیک است.
- cancellation در SubscriptionService auto-renew را متوقف و entitlement را تا expiry حفظ می‌کند.
- مربوط به عملیات فروشگاه است. refund/reconciliation مالی فروشگاه‌ها NOT IMPLEMENTED/NOT VERIFIED.
- refund خودکار provider برای subscription مشاهده نشد؛ ReturnRecord

10.3 سناریوهای شکست

سناریو	رفتار فعلی	اقدام عملیاتی
callback تکراری	Subscription PAID short-circuit + PurchaseRecord unique	log و عدم تمدید دوباره
پرداخت موفق، callback fail	entitlement ممکن است pending بماند ErrorLog ثبت می‌شود؛	تطبیق و callback/reconcile کنید Subscription/PurchaseRecord را با provider panel
token دستکاری/دوباره‌استفاده	mismatch رد؛ externalRef idempotent	error log/400، بررسی fraud
DB هنگام activation fail	transaction rollback	از callback امن DB recovery، verify/replay پس

سناریو	رفتار فعلی	اقدام عملیاتی
provider unavailable	checkout/verify fail	test :maintenance switch provider فقط پس از پیام
wallet callback تکراری	updateMany claim + transaction	no double credit

موفق ولی callback از دست رفته یافت نشد. P1: ابزار superadmin برای re-verify PENDING بر اساس provider بسازید.
Gap: job خودکار reconciliation برای پرداخت‌های

11. Myket و Cafe Bazaar

Myket 11.1

مورد	وضعیت				
package	com.veyo.app - VERIFIED				
SDK	com.github.myketstore:myket-billing-client:1.19 - VERIFIED				
Native plugin	purchase, restore, consume, availability - VERIFIED				
Server verify	X-Access-Token - VERIFIED in code/tests یا Myket partner endpoint				
امنیت	server فقط access token پذیرفته ولی token client :SKU server-side :shop/intent به bind payload تصادفی			VERIFIED	
SKU	SKU peyvo.{pro هشت	business}.{1m	3m	6m	NEEDS CONFIRMATION تا تطبیق console میگوید placeholder comment :{12m
credential	settings تنظیم شده اند و access token در RSA	VERIFIED presence only			
خرید واقعی/approval	NOT VERIFIED				
restore	verify سمت سرور و native query inventory	end-to-end NOT VERIFIED :IMPLEMENTED			
renewal/refund	refund یافت نشد reconciliation route :autoRenew false	NOT IMPLEMENTED			

پرداخت مستقیم بانکی داخل build فروشگاه‌ها را رد کند؛ کد isMyketAndroidApp (وب‌گیت‌وی را در Android پنهان می‌کند. APK/AAB با همان signing key ساخته، روی device دارای Myket تست و سپس console submit شود. Review ممکن است Release: versionCode باید همیشه افزایش یابد،

Cafe Bazaar 11.2

- package و APK عمومی مشترک ممکن است استفاده شود، اما flavor مستقل Bazaar در Gradle وجود ندارد.
- فیلدهای RSA و dynamic discount در PlatformSettings و UI هستند.
- هیچ provider verify، native plugin، Bazaar Billing SDK یا route خرید بازار یافت نشد.
- بنابراین خرید درون‌برنامه‌ای Bazaar ناتمام است و صرف ذخیره کلید به معنی آمادگی نیست.
- restore/renew/cancel/refund بازار NOT IMPLEMENTED.

12. معماری Android / Capacitor

مورد	مقدار تأییدشده
Capacitor	8.4.2
appId/package	com.peyvo.app
version	versionCode 3 / 1.2
webDir	android-shell
server URL	https://peyvo.ir, cleartext false
min/target/compile SDK	android/variables.gradle و root config: قبل release دوباره بررسی شود از
Java	17
native plugins	MyketBilling, NativeContacts, AppVersion
permissions	INTERNET, FINE/COARSE LOCATION
build flavors	flavor مستقل وجود ندارد؛ یک build با Myket SDK
signing	Git credential خارج از محیط یا *_PEYVO_KEYSTORE یا Android Studio UI: credential های
update	API /api/app-version و banner؛ APK direct download

12.1 ساختها

```
npm ci
npm run check
npm run android:sync
cd android
.\gradlew.bat assembleDebug
.\gradlew.bat assembleRelease
```

• Development: assembleDebug, signing debug خودکار.

با env signing و versionCode جدید. سپس signature/package/version را با apksigner/aapt بررسی کنید.

• Production/Myket: assembleRelease

• Bazaar build اختصاصی واقعا پیاده نشده؛ تا افزودن Bazaar billing/flavor نمی‌توان دستور معتبر جداگانه ارائه کرد.

UI بدون APK جدید دیده می‌شوند؛ تغییر SDK، permission، native plugin، یا version detector حتماً APK جدید می‌خواهد.

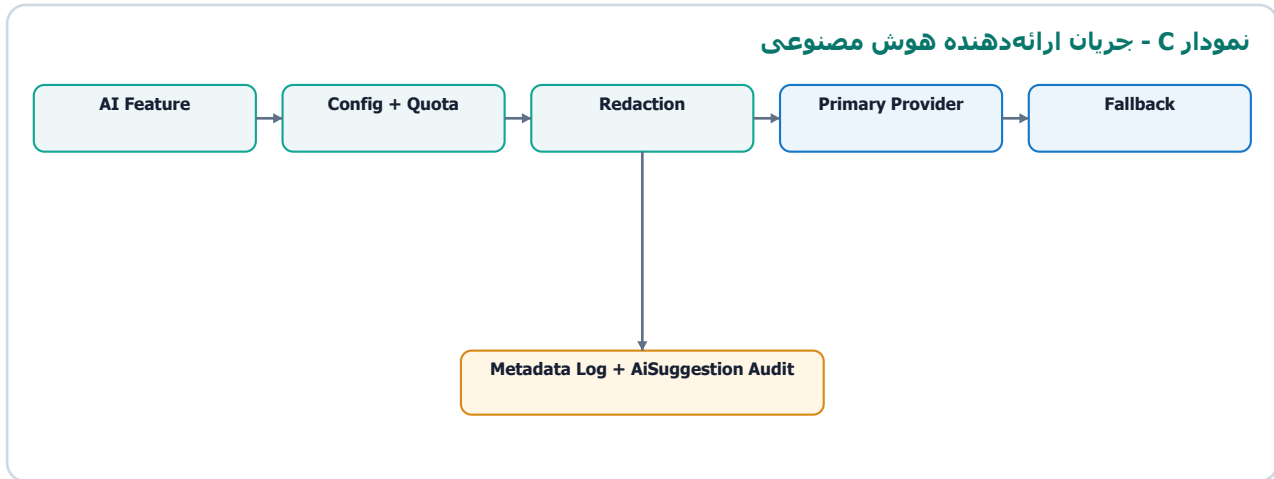
• چون اپ WebView به دامنه production متصل است، بسیاری تغییرات

در store را از بین ببرد. یک نسخه رمزگذاری‌شده آفلاین، یک نسخه escrow نزد فرد دوم و دستور بازیابی مکتوب الزامی است.

ریسک signing key: گم‌شدن keystore/password ممکن است امکان آپدیت همان package

13. معماری AI

13.1 نمودار C



- lib/ai abstraction شامل probe، logger، redaction، quota، config، registry، types و service است.
- providerها: disabled، mock و OpenAI-compatible /chat/completions.
- انتخاب provider از PlatformSettings، سپس env و default؛ business logic تغییر نمی‌کند.
- retry، timeout، محدود برای خطاهای transient و fallback مستقل موجود است.
- quota در RateLimitBucket است و در outage fail-open می‌شود.
- metadata log می‌شود، نه prompt/response؛ AiSuggestion خروجی و inputSummary redacted را نگه می‌دارد.
- keyها در PlatformSettings رمزشده و به browser برگشت داده نمی‌شوند.
- وضعیت production هنگام بررسی: key primary؛ aiEnabled=false، provider disabled؛ موجود ولی استفاده نمی‌شود.
- را ثبت، Connection Test را اجرا، fallback و quota را تنظیم و سپس enable کنید. برای rollback فوراً aiEnabled=false.
- تعویض provider: در AI، Super Admin را خاموش نگه دارید، provider/base URL/model/key

14. قابلیت AI: دستیار پذیرش تعمیر

damage را می‌فرستد؛ سرویس redaction انجام می‌دهد؛ خروجی JSON سه‌بخشی parse و با disclaimer نمایش می‌دهد. جریان: کاربر مجاز در ticket، مدل دستگاه + lane + شرح اولیه + notes

می‌یابد. Quota: هر تلاش سهم روزانه shop را مصرف می‌کند؛ صفر یعنی بدون cap. Store outage باعث fail-open می‌شود. قطعی، قیمت قطعی، تغییر ticket، تصمیم خودکار یا دستور تعمیر خطرناک. شکست: نتیجه safe-negative؛ جریان پذیرش ادامه قیمت و اطلاعات پرداخت. خروجی مجاز: خلاصه، پرسش‌های پیشنهادی، توضیح قابل فهم برای مشتری. غیرمجاز: تشخیص deviceModel، laneLabel، issueInitial، customerDamageNotes. عمداً خارج: نام، موبایل، ایمیل، IMEI، passcode، فیلدهای استفاده‌شده:

15. پایش و عیب‌یابی

15.1 سایت Down

1. `https://peyvo.ir` و `DNS/SSL` را از شبکه دیگر تست کنید.
2. `Vercel Status` و آخرین `deployment/log` را ببینید.
3. `health` وابسته `DB` را با `login` یا `route` امن بررسی کنید.
4. `DNS NS` باید `Vercel` باشد؛ دامنه `expiry` را در `NIC` بررسی کنید.
5. `deployment` سالم قبلی را `rollback` و سپس علت را جداگانه رفع کنید.

15.2 Vercel deployment failed

- `Build log` را در مراحل `prisma generate`, `prisma migrate deploy`, `next build` تفکیک کنید.
- `env presence` را بدون چاپ مقدار کنترل کنید.
- `migration` ناموفق را در جدول `prisma_migrations` و `SQL` همان فایل بررسی کنید.
- `build` را با دیتابیس `staging` بازتولید کنید؛ روی `prod` از `migrate dev` استفاده نکنید.

15.3 Database connection failed

- `credential rotation` و `Neon status`, `project compute`, `connection limit`, `host/SSL` را بررسی کنید.
- `lib/db.ts` و `Vercel function logs`؛ هیچ `URL` را `paste` نکنید.
- پس از `npx prisma migrate status`, `restore` و شمارش رکوردهای بحرانی را روی مقصد تستی انجام دهید.

15.4 Prisma migration failed

- فایل `migration` و `error code`؛ از `edit migration` اجراشده پرهیز کنید.
- `migration` جدید اصلاحی بسازید؛ در موارد `partial` با `prisma migrate resolve` فقط پس از `audit`.
- قبل هر تغییر، `backup/PITR timestamp` ثبت شود.

15.5 پرداخت موفق ولی اشتراک فعال نیست

- `Super Admin ErrorLog` با `source payment` و `route callback`.
- `Subscription` بر اساس `id/status/authority` و `PurchaseRecord externalRef` بررسی شود.
- `provider panel` مبلغ/`ref` را مقایسه؛ `token` را در `ticket/chat` نگذارید.
- `verify` مجدد کنترل‌شده و `idempotent`؛ تغییر دستی `plan` فقط با `audit` و مدرک پرداخت.

15.6 SMS ارسال نشد

- `Lookup enabled`, `settings presence`، نام دقیق `template` و `sender` را بررسی کنید.
- `Kavenegar balance/status/rejected content`؛ خطاهای `lib/sms.ts` در `logs`.

- intake، OTP و ready مسیرهای جدا دارند؛ ready در lookup بدون template عمدا error می‌دهد.

AI connection failed 15.7

- ابتدا Super Admin AI test؛ model و aiEnabled، provider، base URL
- .error kind: auth/rate_limit/network/timeout/invalid_response
- fallback و quota؛ در بحران AI را خاموش کنید، محصول اصلی باید کار کند.

Android app fails 15.8

- اینترنت، TLS و بازشدن در peyvo.ir؛ browser؛ WebView/Chrome update
- (Capacitor logs (adb logcat و package/version/signature
- Myket؛ نصب بودن SKU/payload، SDK setup، public key، Myket، server verify

15.9 خرید Myket/Bazaar

- intent - Myket: native receipt -> /api/billing/myket/verify -> PurchaseRecord -> consume >
- billing: Bazaar؛ پیاده نشده؛ failure «تنظیمات» نیست، gap محصول است.

16. پاسخ به حادثه

حادثه	نشانه	اقدام فوری/مهیار	بازبایی و اعتبارسنجی
DB outage	login/API errors	freeze deploy، status provider	restore/PITR، counts، login/payment smoke
Vercel outage	5xx/timeout	status، اطلاع رسانی	rollback یا provider جایگزین، DNS
DNS/domain	NXDOMAIN/cert	registrar lock/expiry/NS	restore Vercel NS، SSL 200
Gateway outage	checkout/verify fail	disable، عدم تکرار کور CTA/maintenance	reconcile pending، provider switch tested
SMS outage	OTP/notification fail	status Kavenegar، alternate support	rotate key/template، test recipient
AI outage	helper unavailable	aiEnabled=false	core smoke :test provider/fallback
Credential leak	unauthorized usage	preserve logs، فوراً revoke/rotate	update env/settings، redeploy، audit
GitHub compromise	commits/releases ناشناس	revoke sessions/tokens، protect branch	restore trusted commit، rotate integrations
bad deployment	5xx/regression	promote previous deployment	DB compatibility check :forward fix
DB corruption	missing rows/columns	stop writes، snapshot evidence	PITR to new DB، compare counts، switch URL
signing key loss	store update rejected	escrow، توقف ساخت با key جدید جست و جوی	store احتمال package جدید recovery process
developer account loss	no release access	recovery email/2FA codes	transfer ownership/add backup admins

هر حادثه: زمان شروع، scope، commander، تصمیمها، RPO/RTO، credential rotations، و postmortem بدون secret ثبت شود. در

17. چرخش Credentials

- DB: user/password جدید بسازید، Vercel env را تغییر، redeploy و smoke؛ سپس credential قبلی revoke.
- NextAuth: مقدار جدید همه JWTها را نامعتبر می‌کند؛ maintenance window و اطلاع logout.
- OTP secret: OTPهای باز نامعتبر می‌شوند؛ بعد از expiry window rotate.
- دارید. اگر بدون migration عوض شود، decrypt رشته خالی می‌دهد و سرویس‌ها/passcodeها ظاهراً «تنظیم نشده» می‌شوند. را decrypt و با کلید جدید re-encrypt کنید؛ شامل PlatformSettings و Ticket passcode. نسخه امن کلید قدیم را تا verify نگه
- SECRETS_MASTER_KEY: مستقیم تعویض نکنید. با کلید قدیم همه ciphertextها
- Payment/SMS/AI/Myket: ابتدا credential جدید، update encrypted settings/env، test، سپس revoke قدیمی و monitor.
- Bazaar: کلید public را طبق console replace؛ token/private material فقط server/secret manager.
- Android معمولی ممکن نیست؛ از store key-upgrade/recovery رسمی استفاده کنید. keystore را در Git یا PDF نگذارید. signing: rotation

18. برنامه تداوم کسب و کار

اگر توسعه دهنده اصلی در دسترس نباشد

1. هویت اپراتور جایگزین و اختیار کتبی را تأیید کنید.
 2. دسترسی دامنه/NIC و expiry/NS را بازیابی کنید.
 3. GitHub owner/repo/branch protections و commit سالم را تثبیت کنید.
 4. Vercel project، env presence، domain و آخرین deployment را بازیابی کنید.
 5. Neon project، backup/PITR و سلامت schema/data را تأیید کنید.
 6. یک backup مستقل رمزگذاری شده بگیرید و restore آزمایشی انجام دهید.
 7. پرداخت وب و callback را با مبلغ تست کنترل شده بررسی کنید.
 8. Kavenegar/OTP/intake/ready را تست کنید.
 9. Myket/Bazaar accounts، package، product SKUs و signing key escrow را بازیابی کنید.
 10. APK موجود را نگه دارید؛ بدون signing key release جدید نسازید.
 11. ErrorLog، Vercel logs، uptime alert و کانال پشتیبانی مشتری را فعال کنید.
 12. مالک پشتیبان برای همه Critical services اضافه و فهرست دسترسی امضا شود.
- > Monitoring اول: 24 ساعت
-> Domain -> GitHub -> Vercel -> Neon -> Backup -> Payment/SMS -> Android stores
اولویت

19. چک لیست یک صفحه ای اضطراری

این صفحه را چاپ کنید؛ credentialها را در آن ننویسید.

سرویس های حیاتی

- [] Domain/NIC: peyvo.ir - مالک/ایمیل بازیابی: _____
- [] GitHub: behnam391/repair-saas-final - مالک پشتیبان: _____
- [] Vercel project/team: _____ - آخرین deployment سالم: _____
- [] Neon project/region: _____ - آخرین PITR/backup: _____
- [] Payment owner/support: _____
- [] Kavenegar owner/support: _____
- [] Myket/Bazaar accounts: _____
- [] Android signing escrow location: _____

مسیرهای فوری

- Production: <https://peyvo.ir>
- Download: <https://peyvo.ir/download>
- - Git deploy: commit •> Vercel <push main -
- - Rollback: Vercel آخرین نسخه سالم - Deployments •> Promote >
- - test <update DATABASE_URL •> Neon PITR DB recovery: یا restore dump روی DB جدید -
- Payment trace: Subscription/PurchaseRecord + provider panel + ErrorLog
- Location 2: _____ Backup location 1: _____

تماس ها

- Incident commander: _____ / _____
- Developer backup: _____ / _____
- Domain/hosting contact: _____
- Payment/SMS contact: _____

قاعده: هیچ secret در پیامرسان، عکس، تیکت عمومی یا این برگه نوشته نشود.

20. نمودارهای وابستگی

تغییر billing SDK، datastore، provider یا server URL باید همزمان این نمودارها، inventory و status matrix را به روزرسانی کند. نمودارهای A، B و C در بخش‌های 2، 10 و 13 مرجع رسمی معماری این نسخه‌اند. هر

21. ماتریس وضعیت فعلی

حوزه	وضعیت	Production Ready	ریسک	اقدام بعدی
Web	Vercel روی live 200	Yes	Medium	CSP و uptime alert
Database	Neon/Postgres connected	Yes	High	PITR/retention + restore drill
Android	Capacitor 1.2/code3	Yes for direct APK	High	signing escrow + AAB process
Bazaar	listing assets/settings only	No for IAP	High	billing provider/flavor/server verify
Myket	SDK+server verify implemented	Conditional	High	real purchase/restore/review test
Payments	فعال، abstraction چندگانه Zarinpal	Yes	Medium	reconciliation job/runbook
SMS	Kavenegar Lookup enabled	Yes	Medium	rotate exposed key + delivery monitor
AI	architecture ready, disabled	No real AI currently	Low	privacy/DPA + controlled pilot
Backups	daily Telegram code/config	No, incomplete coverage	Critical	model sync + PITR + encrypted offsite
Monitoring	ErrorLog + Vercel logs	Partial	High	external uptime/error alerting
Security	roles/encryption/idempotency	Partial	High	verify master key, RLS/tests, key hashing
Domain	active, Vercel DNS	Yes	Critical ownership	document registrar + backup owner
Deployment	> Vercel + migrateGitHub - deploy	Yes	Medium	staging and migration gate

22. تأیید شده، تأیید نشده و اقدام انسانی

VERIFIED

- public domain و commit، repository، branch main
- HTTPS response و Vercel hosting، DNS nameservers
- package Android و Next.js/Prisma/PostgreSQL/Capacitor versions
- 18-08-2026 و 40 test موفق در API route file 121
- وجود SMTP، Telegram backup config، Neshan، Zarinpal، Kavenegar و store credentials فقط به صورت boolean presence
- idempotent subscription service و Myket SDK/plugin/server verification
- AI architecture و خاموش بودن provider production در زمان بررسی
- نبود RLS migration و ناقص بودن backup model coverage
- عدم یافتن private signing key/keystore/شناخته شده Kavenegar secret در Git

NOT VERIFIED

- مالک/Team و Project ID های Vercel/Neon و Region قانونی
- registrar/holder دامنه، تاریخ expiry و recovery contacts
- Vercel env های واقعی مانند NextAuth/master/cron/blob
- PITR، retention، Neon plan و آخرین backup موفق
- موفقیت روزانه Telegram cron و محرمانگی/retention مقصد
- مالک و 2FA حساب های payment/SMS/stores
- انتشار نهایی و approval مایکت/بازار و خرید واقعی end-to-end
- deployment identifier جاری و commit-to-deployment attestation
- وجود monitoring/alerting خارجی یا SLA

REQUIRES HUMAN ACTION

- تکمیل Access & Ownership Map و افزودن backup owner
- rotation فوری Kavenegar credential افشاشده در گفت و گو
- تأیید و escrow SECRETS_MASTER_KEY و Android signing key
- فعال/ثبت کردن Neon PITR و restore drill
- اصلاح پوشش backup/restore و رمزگذاری offsite
- تست واقعی Myket و تصمیم برای پیاده سازی Bazaar IAP
- محدود سازی کلید Neshan به دامنه و اصلاح endpoint عمومی
- راه اندازی uptime/security alerts و secret scanning CI

23. فراداده و کنترل تغییر سند

بازبینی: ماهانه و پس از هر migration/provider/store release. تاریخچه نسخه: baseline - 1.0 بر اساس commit درج شده.
سند: مالک فنی پشتیبان: تاریخ بازبینی بعدی: چرخه مالک

24. الزامات نگهداری PDF

با چاپ آن نباید در repository عمومی منتشر شود، زیرا اگرچه secret ندارد، نقشه عملیاتی و نقاط شکست را توصیف می‌کند. این Markdown تولید شده، دارای RTL، صفحه‌شماری، header/footer، فهرست و نمودارهای بازطراحی‌شده است. فایل PDF رسمی همراه

25. اعتبارسنجی نهایی

- [x] هیچ مقدار واقعی password/API key/token/private key/connection string در متن قرار نگرفت.
- [x] claim] xهای معماری با repository و پیکربندی خواندنی تطبیق داده شد.
- [x] URL] عمومی و DNS بررسی شد.
- [x] command] xهای package.json بررسی و npm run check با 40 test موفق اجرا شد.
- [x] diagram] xها در PDF به شکل native بازطراحی شدند.
- [x] PDF] x پس از تولید با parser باز و متن آن برای الگوهای secret اسکن می‌شود.
- [] dashboardهای بیرونی باید توسط مالک طبق NOT VERIFIED تکمیل شوند.

پنج ریسک مهم

1. بکاپ ناقص و restore اثبات نشده.
2. وابستگی تک‌نفره حساب‌ها و signing key.
3. tenant isolation فقط در برنامه و بدون RLS.
4. وضعیت نامعلوم master key و plaintext fallback.
5. monitoring/reconciliation خارجی ناکافی.

پنج اقدام فوری

1. مالک پشتیبان و 2FA/recovery برای همه Critical services.
2. rotation کلید SMS افشاشده و تأیید master key.
3. Neon PITR + daily encrypted pg_dump + restore drill.
4. اصلاح BACKUP_MODELS/RESTORE_ORDER و ساخت alert برای cron.
5. signing key escrow و تست خرید واقعی Myket؛ سپس تصمیم Bazaar.